KAKEIBO APP

セキュリティチェック報告書

生成元: docs/security-check.md | 生成日時: 2026/04/25 23:49

セキュリティチェック報告書

1. 実施概要

- 対象アプリ: かわいい家計簿 / `kakeibo-app`
- 本番 URL: `https://kawaii0214.vercel.app`
- 実施日: 2026-04-24（最終更新: 2026-04-25）
- 実施範囲: 依存パッケージ監査、ビルド検証、静的シークレット検査、API 防御状況の確認、本番 URL 確認

2. 数値サマリー

- セキュリティ総合評価: `86%`
- `npm audit` 脆弱性件数: `4`
- Critical: `0`
- High: `0`
- Moderate: `4`（postcss <8.5.10 XSS、next / auth0 / next-intl の依存チェーン由来。**ビルド時ツールのみ、実行時バンドル非含有**）
- Low: `0`
- Git 管理下のハードコード秘密情報検出件数: `0`
- Git 管理下の `.env` 系ファイル件数: `1`
- 管理対象の `.env` 系ファイル: `.env.example` のみ
- `POST` API ルート数: `19`
- `same-origin` 防御あり: `16 / 19`（`84.2%`）
- `rateLimit` 適用あり: `7 / 19`（`36.8%`）
- ビルド失敗件数: `0`

- 非ブロッキング build warning 件数: `2`

3. 総合評価の算出方法

- 今回の総合評価は、静的検査とビルド検証の結果を 100 点満点で重み付けして算出
- 依存脆弱性: `25 / 30` （Moderate 4 件あり、ただしビルドツール由来のため重篤度減点）
- シークレット管理: `25 / 25`
- リクエスト起点保護: `16.8 / 20`
- レート制限: `3.7 / 10`
- 品質ゲート: `15 / 15`
- 合計: `85.5 / 100` → 四捨五入して `86%`

3.1 配点の考え方

- 依存脆弱性は `npm audit` の Moderate 4 件を反映（Critical / High は 0）。対象が postcss ビルドツールのみで実行時バンドルに含まれないため、30 点中 25 点
- シークレット管理は Git 管理下のハードコード秘密情報 `0 件` を満点評価
- リクエスト起点保護は `same-origin` を基本指標とし、`16 / 19` のため `84.2%` を 20 点へ按分
- レート制限は `7 / 19` の適用率 `36.8%` を 10 点へ按分
- 品質ゲートは ESLint、TypeScript、`next build` が通過しているため満点

3.2 解釈

- `86%` は「静的・構成・ビルド観点では良好だが、依存チェーンの Moderate 脆弱性と rateLimit 未適用ルートに改善余地あり」
- postcss の脆弱性はビルド時のみ影響し、エンドユーザーの実行環境へは到達しない
- 主な改善余地は `rateLimit` の適用拡大と、外部からの動的ペネトレーションテスト未実施の 2 点

4. 実施コマンド

- `npm audit --json`
- `./node_modules/.bin/eslint.cmd .`
- `node ./node_modules/typescript/bin/tsc --noEmit --pretty false`
- `npm run build`

- `git grep -n -I -E "(AIza ... |sk_live_ ... |PRIVATE KEY ... |AKIA ... |ghp_ ... )" -- .`
- `git ls-files .env .env.local .env.example .env.preview.local .vercel`
- API ルート走査:

```
POST_ROUTES=19
SAME_ORIGIN=16
RATE_LIMITED=7
MISSING_SAME_ORIGIN:
src/app/api/auth/google/callback/route.ts
src/app/api/auth/line/callback/route.ts
src/app/api/auth/send-email/route.ts
```

5. 結果詳細

5.1 依存パッケージ監査

- `npm audit` で Moderate 4 件を検出（postcss <8.5.10 XSS）
- 脆弱性パス: `next` → `postcss`, `@auth0/nextjs-auth0` → `postcss`, `next-intl` → `postcss`
- postcss はビルドツール（CSS 変換）であり、実行時バンドルには含まれない
- エンドユーザーの実行環境への影響はなく、ビルド作業者の環境でのみ問題が発生する可能性がある
- `next` の Major バージョンアップが確定するまでは影響を許容可能と判断
- 現時点での依存数は約 `582`（production 依存 `176`）

5.2 シークレット管理

- Git 管理下ファイルに対する静的スキャンでは、典型的な API キーや秘密鍵のハードコードは検出されず
- `.env`、`.env.local`、`.vercel` は Git 管理対象外
- Git 管理下に残っている環境変数ファイルは `.env.example` のみ

5.3 API 防御

- `POST` を持つ API ルートは `19`
- そのうち `16` ルートに `requireSameOrigin()` が入っており、一般的なブラウザ起点の CSRF 対策を実施

- `7` ルートに `rateLimit()` が入り、短時間連打の抑制を実施
- 以下 3 ルートは `same-origin` の代わりに別の保護手段を採用:

  - `auth/google/callback` : Auth0 / OAuth PKCE フロー（state parameter 検証）で保護 - `auth/line/callback` : Auth0 / OAuth PKCE フロー（state parameter 検証）で保護 - `auth/send-email` : Supabase hook の JWT / 署名検証で保護

5.4 品質ゲート

- ESLint: `0` errors / `0` warnings
- TypeScript: `0` errors
- `next build` : 成功
- ビルド警告は Auth0 依存からの warning が `2` 件あるが、出荷ブロッカーではない

6. 残課題と所見

- `rateLimit` は全 `POST` API に一律ではないため、将来的には対象拡大の余地あり
- `npm audit fix` を実行しても `next` 等の Major 依存を巻き込むため、現状は手動 upgrade 待ち
- Auth0 の `dpopUtils.js` に起因する build warning は依存側の挙動で、現状は機能阻害なし
- 今回は静的検査とビルド検証が中心であり、外部からの動的ペネトレーションテストまでは未実施
- LINE / Google OAuth の Callback URL は本番 URL に合わせて各開発者コンソールへ登録が必要

7. 総合判定

- 今回の実施範囲では、Critical / High の脆弱性は `0 件`
- Moderate 4 件はビルド時ツール（postcss）由来のみで、実行時影響なし
- 重大な秘密情報の Git 混入も検出されず
- ビルド、型検査、Lint を通過しており、現時点のコードベースはデプロイ可能な状態
- 総合評価は `86%` で、本番運用に耐える状態。postcss のアップグレードと rate limit の拡張でさらに引き上げ可能